



OCCAR-EA

OCCAR Management Procedure

Title:	<u>Handling of NON-CLASSIFIED OCCAR Information</u>	
QMS document Number:	OMP 12	Date: 01/10/2024
Document Filename:	20241001OMP12_Handling of Non-Classified OCCAR Information_Issue5	
Current Issue status:	Issue 5	
Contact details:	Central Office, OCCAR-EA Bonn Email: questions@occar.int	

Approved for issue:

OCCAR SNS Number:
CO/CSD/2024/00065

This document replaces: OMP 12 Issue 4 dated 19/07/2017

Record of changes

Date	Issue	Changes
03/2001	OMP 4.6.2.4 Issue 1	Approved by the BoS on 15/12/00. Approved for issue by the Director of OCCAR-EA on 13/03/01.
14/02/05	OMP 12 Issue 1	Update of the OMP number in accordance with the structure of OMPs adopted by the BoS on 31/03/01. Application of the current OMP template.
01/07/06	2	Converted to the OCCAR-EA graphical house style
09/12/08	3	Review the document with the view to handle sensitive information in the same manner as RESTRICTED. Approved by 19 th BoS on 28/11/08.
19/07/17	4	Complete rewrite; code of conduct introduction.
01/10/24	5	Overall revision, inclusion of OCCAR Unclassified releasable/not releasable to the public, additional administrative markings and provisions for the Cloud service.

Table of Contents

<u>1. Introduction.....</u>	<u>6</u>
1.1 General.....	6
1.2 Basic Principles	6
<u>2. Types of Non-Classified OCCAR Information.....</u>	<u>6</u>
2.1 Information releasable to the Public	6
2.2 OCCAR UNCLASSIFIED	6
2.3 OCCAR UNCLASSIFIED SENSITIVE	7
<u>3. Handling of Non-Classified OCCAR Information.....</u>	<u>8</u>
3.1 Markings	8
3.2 Handling of OCCAR UNCLASSIFIED SENSITIVE Information.....	9
3.2.1 General Requirements	9
3.2.2 Access	9
3.2.3 Release.....	9
3.2.4 Storage	10
3.2.5 Movement.....	10
3.2.6 Addressing	10
3.2.7 Destruction	11
<u>4. Communication and Information System.....</u>	<u>11</u>
4.1 General Requirements.....	11
4.2 Protective Measures	11
4.2.1 Identification, Authentication and Access Control	11
4.2.2 Security Management.....	12
4.2.3 Transmission	13
4.2.4 Cloud Services	14
4.2.5 Physical Security	15
4.2.6 Awareness and Training	15
4.2.7 Maintenance, Repair and Disposal of Equipment	15
4.2.8 Interconnection of CIS	16
<u>5. Loss, Unauthorised Disclosure of OCCAR UNCLASSIFIED SENSITIVE Information or Violations of Handling Instructions</u>	<u>17</u>

List of definitions

Cloud (Computing)	The on-demand availability of computer system resources, especially data storage (cloud storage) and computing power, without direct active management by the user. Large clouds often have functions distributed over multiple locations, each of which is a data centre. Cloud computing relies on sharing of resources to achieve coherence and typically uses a pay-as-you-go model, which can help in reducing capital expenses but may also lead to unexpected operating expenses for users.
Originator of UNCLASSIFIED Information	A person or an entity under whose authority the information has been issued. For OCCAR information, the originator is OCCAR.
Removable Media	Any computer storage device designed to be removed from a computer without powering it down or affecting its operating state. The term includes CDs, DVDs, Blu- Ray Disks, Memory cards, Memory Stick etc., and other various types of storage device (Pen Drives, Hard Drives, Mobile Phones, Tablets etc) compatible with the Universal Serial Bus (USB) and other interfaces.
UNCLASSIFIED Information	Any information or material, which has not been designated and marked with a security classification level, as detailed in OMP11.
OCCAR UNCLASSIFIED SENSITIVE Information	Any UNCLASSIFIED information relating to OCCAR, the unauthorised disclosure of which could adversely affect the interests of OCCAR, its Member States or other States participating in OCCAR Programmes.

List of acronyms

CIS	Communication Information System
(D) DSO	(Deputy) Designated Security Official
FIPS	Federal Information Processing Standard
GSA	General Security Agreement
ICT	Information and Communication Technology
IPSec	Internet Protocol Security
LAN	Local Area Network
PSI	Programme Security Instructions
SLA	Service Level Agreement
S/MIME	Secure/Multipurpose Internet Mail Extensions
SOAP	Simple Object Access Protocol
SSH	Secure Socket Shell
TLS	Transport Layer Security
VTC	Video Teleconference

1. Introduction

1.1 General

OCCAR manages a wealth of information either coming from Members States, Participant States, industries or generated within OCCAR itself. Clearly, given the nature of the Corporation's activities, much of this information needs to be safeguarded. Even for OCCAR information which is deemed to be releasable to the public (e.g., an OCCAR press release or OCCAR information posted on the Internet) changes to its content (loss of integrity) or denial of legitimate access (loss of availability) could result in damage to OCCAR interests.

Consequently, all OCCAR information requires protection to ensure its integrity and availability.

1.2 Basic Principles

Classified information requiring protection in the interest of OCCAR, its Member States or OCCAR Programme Participating States, is safeguarded by the application of appropriate security measures as detailed in OMP 11.

Some OCCAR documentation, though not classified, still needs to be properly protected and distributed in such a way that only persons with a need to know can have access to it.

Procedures for the handling of OCCAR classified information and the Security organization are outlined in the OCCAR Security Regulations (OMP 11) and subsequent security instructions. OMP 12 lays down the basic principles and minimum standards applicable within OCCAR, its Member States, Programme Participating States and related industry, for the protection and handling of **non-classified OCCAR Information** provided or generated in connection with an OCCAR Programme or activity.

OCCAR Programme Divisions may implement security controls that are more stringent than those outlined in this OMP; but no less stringent. This can be done via their respective Programme Security Instruction (PSI).

For OCCAR information, the originator is OCCAR.

2. Types of Non-Classified OCCAR Information

OCCAR information which does not require a security classification is known as **non-classified OCCAR information** and falls into three categories:

2.1 Information releasable to the Public

Such information has been reviewed in accordance with OCCAR procedures and is determined to be releasable to the public; such information will carry **no marking**.

2.2 OCCAR UNCLASSIFIED

Such information does not carry a security classification but will be marked **OCCAR UNCLASSIFIED**. It shall only be used for official purposes and only individuals, bodies or organisations that require it for official OCCAR purposes may have access to it. The majority of OCCAR work falls into this category as it is both non-classified and not releasable to the public.

2.3 OCCAR UNCLASSIFIED SENSITIVE

Such information does not carry a security classification but will be marked **OCCAR UNCLASSIFIED SENSITIVE** and it may carry an administrative marking (see paragraph 3.1). It shall only be used for official purposes and only individuals, bodies or organisations with a confirmed Need-to-Know may have access to it. It is subject to protection, administrative control and release procedures as set out in the following paragraphs.

The characteristics of Availability, Integrity and Confidentiality of the different types of Non-Classified OCCAR information are summarised in the following table:

Non-Classified Information	Availability	Integrity	Confidentiality
Information releasable to the Public	For all audiences/public. Any media dissemination is permitted, including online e.g., the OCCAR website.	Integrity only assured at the location of publication e.g., OCCAR internet website. From any other source, integrity cannot be assured.	None once published. No considerations after publication.
OCCAR UNCLASSIFIED	For official purposes. Can be stored on the OCCAR network. Can be shared via email unencrypted. Can also be stored on the OCCAR Extranet.	Not to be edited without originator's permission. For OCCAR information, the originator is OCCAR-EA.	For those that have a need-to-know e.g., OCCAR Staff, Member Nations, Programme Participating States, Industry
OCCAR UNCLASSIFIED SENSITIVE	For official purposes. Can be stored on the OCCAR Network. Can be shared externally via email when encrypted. Internally, within the OCCAR network, encryption is not required. Can also be stored on the OCCAR Extranet provided that all the security requirements at para. 4.2.4 are in place. In case of basic personal data ¹ transmission to external recipients, encryption is not required.	Not to be edited without originator's permission. For OCCAR information, the originator is OCCAR-EA.	For those that have a need-to-know e.g., OCCAR Staff, Member Nations, Programme Participating States, Industry. Subject to protection and administrative control

¹ Basic personal data includes, for example: first and last name, email address, post details etc.

3. Handling of Non-Classified OCCAR Information

3.1 Markings

OCCAR Non-Classified Information will be marked as follows:

- Inform Information releasable to the public. – will carry **no marking**.
- OCCAR UNCLASSIFIED. - Such information will be marked **OCCAR UNCLASSIFIED**.
- OCCAR UNCLASSIFIED SENSITIVE. – Such information will be marked **OCCAR UNCLASSIFIED SENSITIVE** and it may carry an administrative marking.

Administrative markings which may be used to complement OCCAR UNCLASSIFIED SENSITIVE marking are:

- **Commercial:** for information containing commercial or technical details or proprietary information, e.g., information received in procurement actions or contracts;
- **Financial:** to be applied by the originator when, in their judgement, the financial-related content of the document requires protection measures at OCCAR UNCLASSIFIED SENSITIVE level and they want to emphasize the document's domain such as financial;
- **Staff:** for information containing references to named or identifiable OCCAR staff members;
- **Medical:** for information concerning medical reports and related material on personnel.
- **Personal:** for information to be seen only by the individual to whom it is addressed.

Further marking with the name of the programme or Central Office is possible, in order to identify the originator of the information.

Example:

OCCAR UNCLASSIFIED SENSITIVE - Commercial A400M PD
--

TYPES OF NON-CLASSIFIED OCCAR INFORMATION	MARKING
Information releasable to the Public	No marking
OCCAR UNCLASSIFIED	OCCAR UNCLASSIFIED
OCCAR UNCLASSIFIED SENSITIVE	OCCAR UNCLASSIFIED SENSITIVE -
	OCCAR UNCLASSIFIED SENSITIVE -COMMERCIAL (+PD name)
	OCCAR UNCLASSIFIED SENSITIVE -FINANCIAL (+PD name)
	OCCAR UNCLASSIFIED SENSITIVE -STAFF (+PD name)
	OCCAR UNCLASSIFIED SENSITIVE -MEDICAL (+PD name)
	OCCAR UNCLASSIFIED SENSITIVE -PERSONAL (+PD name)

3.2 Handling of OCCAR UNCLASSIFIED SENSITIVE Information

3.2.1 General Requirements

OCCAR UNCLASSIFIED SENSITIVE information shall be handled and stored in a manner to prevent unauthorised access, compromise or unauthorised disclosure. As a minimum, the procedures outlined in the following paragraphs shall be observed and implemented by OCCAR-EA, its contractors and sub-contractors.

3.2.2 Access

Access to OCCAR UNCLASSIFIED SENSITIVE information shall be authorised only to persons having a Need-to-Know for carrying out their duties.

Most operations, support, and troubleshooting performed by ICT personnel do not require access to UNCLASSIFIED SENSITIVE data. In circumstances where such access is required, the originator will be informed and the access will only last until the activity is completed.

Access to OCCAR UNCLASSIFIED SENSITIVE Information by contractors and/or subcontractors participating in the respective OCCAR Programme shall require a contractual security clause for the protection of such information, which will be included in the Programme Security Instructions and be in accordance with this OMP.

3.2.3 Release

OCCAR UNCLASSIFIED SENSITIVE information generated or provided in connection with an OCCAR Programme shall only be released on a strict Need-

to-know basis to: States, International Organisations or other legal entities not participating in the Programme and only with prior written consent of the Originator or the Programme Participating States and only after receiving the commitment from those legal entities to comply with the provisions of this OMP.

When releasing OCCAR UNCLASSIFIED SENSITIVE information carrying STAFF, PERSONAL or MEDICAL as administrative markings, the originator is usually identified as the Human Resources Division. In giving such approval, originators must comply with the provisions of this OMP and the legal regulations concerning the protection of personal data that for OCCAR is the OCCAR Privacy Statement ([OCCAR - Privacy & Data Protection](#)).

3.2.4 Storage

Documents containing OCCAR UNCLASSIFIED SENSITIVE information shall not be left unattended or handled in a manner that could result in unauthorised access.

They shall be stored in locked desks, cabinets or similar containers or be secured in locked rooms/offices.

3.2.5 Movement

The Originator may determine the means of movement, however, consignments containing OCCAR UNCLASSIFIED SENSITIVE information shall be moved, as a minimum, either by:

- ordinary or registered mail, as appropriate;
- commercial courier services;
- personal carriage without formal courier orders by government or company employees or OCCAR-EA staff members; or
- electronic transmission by CIS as detailed in paragraph 4.2.8.

Single envelopes or packaging containing OCCAR UNCLASSIFIED SENSITIVE information shall not bear any markings.

When moving such consignments in person, documents shall remain under permanent personal custody during travel.

3.2.6 Addressing

The recipient's address may indicate that the contents of the consignment should only be seen by, and directly forwarded to, the individual to whom it is addressed,

e.g.,

"PERSONAL for

Mr/Mrs XY at ..."

+ [XY Division/Programme]

+ mailing address (as appropriate)

3.2.7 Destruction

To prevent the unnecessary accumulation of physical OCCAR UNCLASSIFIED SENSITIVE information, it shall be destroyed as soon as possible, provided it has no residual value. Personnel storing physical OCCAR UNCLASSIFIED SENSITIVE information shall review documents at regular intervals (e.g. every six months), in order to determine whether they can be destroyed.

OCCAR UNCLASSIFIED SENSITIVE information, including interim material such as working drafts, shorthand notes or spoilt copies shall be destroyed in a manner to ensure that they cannot be easily reconstructed.

OCCAR UNCLASSIFIED SENSITIVE information stored on CIS storage media shall be deleted or destroyed as described in paragraph 4.2.7.

4. Communication and Information System

4.1 General Requirements

OCCAR UNCLASSIFIED SENSITIVE information handled in electronic form on CIS shall be ensured protection from deliberate or accidental compromise, without inhibiting its use, specifically concerning:

- loss of Confidentiality – unauthorised disclosure or compromise of information to unauthorised individuals;
- loss of Integrity – corruption or unauthorised alteration of information; or
- loss of Availability – untimely access to information by authorised staff.

For this purpose, a baseline set of protective measures has been developed by the OCCAR Member States, which OCCAR-EA, its contractors and sub-contractors shall observe and implement for the handling of OCCAR UNCLASSIFIED SENSITIVE information within CIS.

It is not envisaged for CIS to undertake a formal approval process in order to handle OCCAR UNCLASSIFIED SENSITIVE information. However, the OCCAR-EA Director shall be responsible for ensuring that appropriate protections are in place within OCCAR-EA's scope of business.

4.2 Protective Measures

The protective measures outlined below shall be applied within all OCCAR-EA, contractor or sub-contractor CIS intending to store, forward or process OCCAR UNCLASSIFIED SENSITIVE information provided or generated in connection with an OCCAR Programme or activity, in accordance with section 1. Where exceptions exist, caution should be taken before allowing the CIS to handle such information.

To facilitate assessments, the measures are outlined in tabular format.

4.2.1 Identification, Authentication and Access Control

The Need-to-Know principle shall be enforced through the unique identification of individual users who have controlled access to information based on their job requirements.

ID	Requirements
1.1	All users shall be uniquely identified through the issue of personal account credentials prior to use of the CIS.
1.2	All users shall be authenticated by the CIS before any access to it is granted.
1.3	The use of previously-used passwords shall be prevented.
1.4	Passwords shall be changed whenever they have, or are suspected to have been compromised or disclosed.
1.5	Administrator passwords shall be stored in a protected manner for emergency access (e.g., sealed in envelopes, locked in appropriate security containers, centralised managed by a Password management system).
1.6	Accounts that are no longer required shall be locked or deleted.
1.7	It shall be possible for the authentication process to be terminated for a particular user after an inappropriate number of failed login attempts.
1.8	All passwords shall have a minimum length of 12 characters, with expiration time, not contain user's account name and contain three of the following: at least one lowercase, one uppercase, one number and one special character.
1.9	Privilege-based mechanisms shall be implemented to restrict user access to only the information required to support a given programme or other OCCAR- related activity, taking into account the "need-to-know" principle.
1.10	Access to security and system information shall be granted only to authorised security and/or system administrators.
1.11	The CIS shall lock sessions after a specified period of user inactivity.
1.12	The CIS shall allow user-initiated locking of the user's own session, as defined above.
1.13	CIS and Storage Media used to store, forward, or process OCCAR UNCLASSIFIED SENSITIVE information, shall be physically protected against unauthorised access.
1.14	Wherever possible, encryption systems shall be used to protect data-at-rest within mobile devices and removable storage media.

4.2.2 Security Management

Security mechanisms shall be implemented in order to detect, deter, and defend the system from deliberate and accidental malicious activities.

ID	Requirements
2.1	An audit log of security events shall be generated and maintained.
2.2	The audit trail and associated archive shall be protected from unauthorised deletion and/or modification.
2.3	Access to audit information shall be controlled; access permissions shall be established to permit access only by the appropriate management staff.
2.4	Virus/malicious code detection software shall be installed and it shall be configured to automatically check on the introduction of removable media.
2.5	The virus/malicious code detection software shall be regularly updated.
2.6	Incoming e-mails, files, media and other exchanged data types shall be checked for the presence of malicious code.
2.7	CIS Security incidents shall be reported immediately to the internal security organisation.
2.8	Mobile devices shall indicate discreetly to the user whether it is approved to handle SENSITIVE information or not.
2.9	Backup, recovery and business continuity requirements shall be considered.

4.2.3 Transmission

Provided that appropriate encryption systems are used (see below), OCCAR, contractors and sub-contractors may transmit OCCAR UNCLASSIFIED SENSITIVE information using any CIS – including public networks – in various data formats; such as e-mail, voice call, video tele-conference (VTC), removable media and direct file transfer.

The types of encryption system to be used shall be determined by the authority responsible for authorising the use of the system (for example, OCCAR-EA as contracting authority). At the very least, encryption products used to protect OCCAR UNCLASSIFIED SENSITIVE information shall make use of recent, relevant and active “state of the art” commercial cryptography standards (e.g., RSA, ECC, DH or equivalent for asymmetric encryption, AES256, Blowfish, ChaCha20 or algorithms of equivalent strength for symmetric encryption).

Encryption tools approved by OCCAR to transmit OCCAR RESTRICTED information can also be used for the transmission of OCCAR UNCLASSIFIED SENSITIVE information.

ID	Requirements
3.1	Removable media used to store OCCAR UNCLASSIFIED SENSITIVE Information shall be marked in accordance with Section 3.1, in such a manner that any recipient shall know it contains OCCAR UNCLASSIFIED SENSITIVE Information.
3.2	OCCAR UNCLASSIFIED SENSITIVE information shall not be transmitted via public network (e.g., by telephone, fax, VTC, e-mail, or via online services) unless a "state of the art" encryption system is used. Where exceptional urgent circumstances apply, telephone conversations, video conferences and facsimile transmissions containing OCCAR UNCLASSIFIED SENSITIVE information may be conducted in clear text, subject to the following conditions: ▪ an appropriate encryption system is not available, and; ▪ time is of paramount importance.
3.3	When wireless LAN technology is used, the range of access points shall be set to minimise exposure to external attacks.
3.4	The encryption used for transmission over wireless LAN shall be at "state of the art".

4.2.4 Cloud Services

UNCLASSIFIED SENSITIVE information is permitted to be stored in Cloud services, provided that at least the following Security measures are in place:

ID	Requirements
4.1	The transmission of data from/to the Cloud is encrypted using an appropriate encryption protocol/software (e.g., for protocol, TLS, IPSEC, SSH and for encryption tools which uses as encryption RSA, ECC, DH, AES, Blowfish, ChaCha20, etc.).
4.2	The data, when at rest, is encrypted using symmetric encryption compliant with at least FIPS 140-2 specifications (e.g., GnuPG vs Desktop, BitLocker, etc.).
4.3	The datacentres storing and processing the data is located in one of the OCCAR Members States.
4.4	An appropriate audit tool is implemented to grant Cloud provider system engineers/administrators access to OCCAR data for technical issues and to audit all their activities.
4.5	When UNCLASSIFIED SENSITIVE data is to be processed, a detailed risk assessment, written according to a recognised risk methodology, is required.
4.6	A clearly defined SLA is of paramount importance. The objective of the SLA is to state, with due details, what the roles and responsibilities are in delivering the intended services, and the quality level, security

	features and overall assurance of such services.
4.7	Security measures involved with secure cloud service provision are to be included and referred to in the SLA, which normally includes elements such as: audit requirements, regulatory requirements, certification requirements, business continuity, disaster recovery, incident management, patch management, multi-tenancy policy, configuration management, supply chain security requirements and jurisdictional/legal aspects.

4.2.5 Physical Security

Each page of hard-copy output or removable computer storage media shall be marked with the appropriate administrative marking as described under Section 3.1.

ID	Requirement
5.1	Workstations, mobile devices and removable media used to handle OCCAR UNCLASSIFIED SENSITIVE information, and any hard-copy output shall be appropriately marked and protected.

4.2.6 Awareness and Training

A security education and awareness programme shall emphasise the importance of information marking, labelling and the balance between “responsibility-to-share” and “Need-to-know”.

ID	Requirement
6.1	Users shall be trained in the appropriate security actions they should be expected to perform, such as labelling/marketing and dealing with a malicious software infection.

4.2.7 Maintenance, Repair and Disposal of Equipment

Measures shall be implemented to protect equipment developed to store, forward or process OCCAR UNCLASSIFIED SENSITIVE information during maintenance, repair, replacement, and/or disposal.

On fixed data media (including internal data storage and removable storage), OCCAR UNCLASSIFIED SENSITIVE information shall be deleted by overwriting with commercial sanitisation tools.

Due to the quantity of OCCAR UNCLASSIFIED SENSITIVE information contained in OCCAR CIS systems, service supplier staff shall only intervene under the supervision or presence of an OCCAR ICT staff member. Remote maintenance is forbidden unless appropriately supervised.

ID	Requirements
7.1	Equipment returning from external maintenance shall be subject to security checks and/or isolated testing prior to re-installation in the operational system.
7.2	Maintenance requiring remote access diagnostic procedures shall be permitted, albeit under strict control or supervision.
7.3	Equipment that has stored, forwarded or processed OCCAR UNCLASSIFIED SENSITIVE Information shall have its persistent storage overwritten using commercial sanitisation tools, unless appropriate encryption is used. Where this is not possible, the data storage shall be removed and retained.

4.2.8 Interconnection of CIS

CIS that intends to store, forward, or process OCCAR UNCLASSIFIED SENSITIVE information may be directly or indirectly connected to other CIS – including public networks such as the Internet – providing measures are established to ensure any UNCLASSIFIED SENSITIVE information being exchanged is appropriately protected.

ID	Requirement
8.1	CIS assets shall mutually authenticate with each other when establishing trusted connections in order to avoid communication with rogue devices masquerading as legitimate service providers.
8.2	Interconnected CIS shall implement techniques to authenticate exchanged data using certificates and digital signatures wherever possible (e.g., TLS, S/MIME, SOAP).
8.3	All users, devices and systems/security administrators shall be subject to an approved identification, authentication and authorisation process when establishing connection to the CIS from external or public networks.
8.4	All information outgoing from a CIS handling OCCAR UNCLASSIFIED SENSITIVE to public networks shall be content-checked at the boundary to ensure no unencrypted classified information is unintentionally released to the public network.
8.5	Bidirectional end-to-end communication (such as voice over IP, collaboration, web conferencing and chat) over public networks shall be limited to OCCAR UNCLASSIFIED conversations only, unless entirely contained within an appropriately encrypted connection or secured VPN.

5. Loss, Unauthorised Disclosure of OCCAR UNCLASSIFIED SENSITIVE Information or Violations of Handling Instructions

Any cases of loss, unauthorised disclosure of OCCAR UNCLASSIFIED SENSITIVE information or any violation of these instructions shall be reported immediately to OCCAR-EA Security Section.

The OCCAR-EA Security Section shall notify the originator of the information about the loss or unauthorised disclosure.

In case of a breach occurring with a contractor or sub-contractor, they should report it to the respective Programme Manager.

Any individual or entity being responsible for violation of these handling procedures renders themselves liable to administrative or contractual responsibility. Such action shall not prejudice any legal action.